

Week 3: Advanced Security and Final Reporting

1. Introduction

This phase focuses on applying advanced security practices including basic penetration testing, logging implementation, and summarizing security best practices. The goal is to demonstrate an understanding of how to monitor, test, and secure an application.

2. Basic Penetration Testing

Basic penetration testing was performed using common input-based attack techniques. Due to the unavailability of public demo servers, testing was simulated using standard payloads.

Test 1: Cross-Site Scripting (XSS)

Payload Used:

```
<script>alert('test')</script>
```

Description:

This payload is used to test whether the application executes injected scripts in user input fields.

Result:

The application is expected to sanitize user inputs and prevent execution of such scripts.

Test 2: SQL Injection

Payload Used:

```
admin' OR '1'='1
```

Description:

This payload attempts to bypass authentication by manipulating SQL queries.

Result:

The application is expected to validate inputs and prevent unauthorized access.

Nmap Usage (Conceptual)

Nmap is a network scanning tool used to identify open ports and services on a system. It helps in detecting potential vulnerabilities and attack surfaces. In this task, Nmap usage is described conceptually.

3. Logging Implementation

Logging is essential for monitoring application behavior and detecting suspicious activities.

Code Implementation

```
const winston = require('winston');

const logger = winston.createLogger({
  transports: [
    new winston.transports.Console(),
    new winston.transports.File({ filename: 'security.log' })
  ]
});

logger.info('Application started');
```

Explanation

The Winston library is used to log application events. Logs are displayed in the console and stored in a file named security.log. This helps in tracking system activity and identifying potential security incidents.

4. Security Checklist

The following security best practices were considered:

- All user inputs are validated
 - Passwords are hashed before storage
 - HTTPS is used for secure data transmission
 - Security headers are implemented
 - Logging is enabled for monitoring
-

5. Final Summary

During Week 3, basic penetration testing techniques were reviewed, logging was implemented, and essential security practices were documented. These measures contribute to improving the overall security of the application.